SIMATS ENGINEERING

SIMATS
Saveetha Institute of Medical And Technical Sciences
(Declared as Deemed to be University under Section 3 of UGC Act 1956)

ASSESSMENT TOOL II- ASSIGNMENT

COURSE CODE: ITA14 **COURSE NAME: Ethical Hacking**

COURSE OUTCOME COVERED

CO1: Apply the principle of the foundational concepts of ethical hacking, including types of hackers, ethical principles, legal frameworks, and the role of responsible disclosure in cybersecurity.

ASSIGNMENTS QUESTIONS

1. A company hires you to test its network but gives you only a one-line email authorization with no defined scope. Halfway through testing, you discover a critical vulnerability in a system that wasn't mentioned in the email. Do you exploit it to prove impact? Justify your answer using ethical hacking principles.
2. You are conducting a penetration test and discover that the client's production database contains real customer financial data. Your test plan calls for exploiting a SQL injection vulnerability. How do you proceed without causing harm, and what precautions should have been taken before the engagement began?
3. During a black-box penetration test, you accidentally trigger a denial-of-service condition on a live production server, causing an outage. Walk through what you should have done to prevent this and what your responsibility is now.
4. A client asks you to test their systems but insists you not inform their IT department, wanting to test the team's real-world detection capability. What ethical and practical risks does this create, and how would you structure the engagement to protect yourself?
5. You're asked to perform a "red team" exercise versus a "vulnerability assessment." Using a real-world scenario of a bank wanting to test physical and digital security, explain how your approach, ethics, and rules of engagement would differ between the two.

Code of Conduct:

I Monisha.K (192421098) *(Name / Reg No) certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment. I understand that any violation of academic integrity rules will result in disciplinary action.*

Rubrics

Criteria	Weightage	Level 4 – Exemplary	Level 3 – Proficient	Level 2 – Developing	Level 1 – Beginning
Understanding of Problem Context	20	Clearly understands the problem and accurately identifies all data-handling requirements and operations	Good understanding with minor gaps	Basic understanding; some requirements unclear	Poor understanding or misinterpretation of the problem
Application of Concepts	30	Accurately applies appropriate data structures and algorithms to solve complex problems	Applies relevant concepts correctly with minor errors	Applies basic concepts with limited accuracy	Fails to apply appropriate concepts
Problem-Solving Approach	20	Logical, well-structured, and efficient approach	Mostly logical approach with minor gaps	Basic approach with some inconsistencies	Illogical or unclear approach
Accuracy of Solution	20	Completely correct code, output and complexity analysis with proper justification	Mostly correct with minor errors	Partially correct solution	Incorrect or incomplete solution
Clarity	10	Clear, well-organized, and properly explained solution	Understandable with minor clarity issues	Limited clarity and explanation	Poorly presented and difficult to understand

Monisha.K [192421092]

1. Handling an Out-of-Scope Critical Vulnerability

Understanding the Problem → "Problem Analysis"

A company has authorized a penetration test through a one-line email, but the testing scope is unclear. During testing, the ethical hacker discovers a critical vulnerability in a system not mentioned in the authorization.

Application of Ethical Hacking Principles

The vulnerability should not be exploited without additional written authorization. Permission to test one system does not automatically authorize testing another system.

Ethical principle	Applications
Authorization	Obtain explict permission
Scope limitation	Test only approved systems
Confidentiality	Protect sensitive information
Non-maleficence	Avoid unnecessary harm
Responsible disclosure	Report the vulnerability securely.

Problem-solving approach.

The tester should stop testing the out-of-system, record the discovery without intrusive exploitation, and notify the authorized client contact. The Teaser should request written approval before continuing. Before testing begins, the agreement should specify target systems, permitted techniques, testing dates, prohibited Techniques, actions, emergency contacts, and reporting procedure.

Accuracy and Justification

Exploiting the vulnerability without permission could damage and create legal consequences. Reporting it first is safer and professionally responsible

Conclusion

Ethical hacking requires authorization, confidentiality, and minimum harm. Therefore, the tester must obtain clear written permission before exploiting a vulnerability outside the agreed scope.

2. Safe Testing of SQL Injection in Production Databases

Understanding the Problem.

During a penetration test, the tester discovers SQL injection in a production database containing real customer financial information. Testing must not unnecessarily expose or damage this data.

Application of Ethical Hacking Principles

Risk	Precaution
Financial data exposure	Avoid retrieving real records
Data modification	Avoid destructive queries
Service disruption	Use controlled testing
Privacy violation	Follow data-handling rules
Evidence leakage	Store minimum necessary evidence securely.

Problem - Solving Approach

First, the tester should confirm the vulnerability using a controlled, minimally invasive method. Testing should stop before accessing sensitive records or performing potentially harmful actions. Further exploitation requires explicit authorization. Before the engagement, the client should define the testing scope, production - system restrictions, data - protection requirements, emergency contacts, and permitted techniques. A test environment with synthetic data should be preffered when practical. Backup and recovery processes should also be established.

Accuracy and Justification

SQL injection can allow unauthorized database access or modification. Therefore, extracting actual customer information merely to prove the vulnerability is unnecessary and risky.

Conclusion.

The ethical hacker must identify the vulnerability while protecting customer privacy and system availability. Safe testing, clear authorization, and responsible reporting are essential for a successful penetration test.

3. Accidental Denial - of - Service on a Production Server.

Understanding the problem.

During a black - box penetration test, the tester accidentally causes a denial - of - service condition on a live production server, resulting in a outage. This affects system availability and may interrupt business operations.

Application of Ethical Hacking Principles.

Stage	Correct action
Before testing	Identify critical system and risks
During testing	use controlled techniques
During outage	stop related testing immediately
Incident response	Notify the client promptly
After recovery	Document and review the incident.

Problem - Solving Approach.

To prevent the incident, the tester should review The Rules of Engagement, establish testing limits, avoid aggressive availability tests without approval, and agree on emergency procedures

After the outage occurs, the tester must stop the activity and immediately inform the designed client contact. The tester should explain the timeline, affected system, action performed, and observed impact. The tester must cooperate with the clients technical team to restore service safely.

Accuracy and Justification.

The Tester must not conceal The incident or continue testing while the service remains affected. The incident should be documented, investigated, and included in The final report. Preventive measures should be recommended.

Conclusion

An ethical hacker is responsible for minimizing harm, communicating honestly, and supporting recovery. Power planning and immediate incident reporting help reduce The impact of accidental outages.

4. Testing Without Informing the IT Department.

Understanding the Problem

A client wants to test its IT department's ability to detect a realistic cyberattack but asks the ethical hacker not to inform the IT team. This creates operational, ethical, and legal risks if the exercise is poorly controlled.

Applications of Ethical hacking Principles

Risk	Control measure
Mistaken for a real attack	Inform selected senior personal
Business disruption	Establish stop conditions
Unauthorized activity	obtain written authorization
Emergency confusion	Define escalation contacts
Excessive damage	set testing limits

Problem-Solving Approach

The tester should establish a written agreement with authorized management before starting. The agreement must define the scope, objectives, testing period, permitted techniques, emergency contacts, and termination conditions.

A small group of trusted senior personal may know about the exercise while the IT team remains unaware. This preserves the realism of the test while ensuring that someone can intervene if critical systems are affected.

Accuracy and justification.

Controlled secrecy is useful for evaluating real-world detection and response. However, secrecy does not remove the need for authorization or excuse activities outside the agreed scope.

Conclusion.

The exercise should balance realism with safety. Written authorization, limited secrecy, emergency procedures, and clear responsibilities protect the organization while allowing its detection capabilities to be evaluated effectively.

5. Red team Exercise v Vulnerability Assesment.

Understanding the Problem

A bank wants to evaluate its physical and digital security. It must choose an approach based on whether it wants to identify weaknesses systematically or simulate a realistic attacker.

Application of Ethical Hacking concepts.

Aspect	Vulnerability assesment	Red team excercise
Objective	Identify security weaknesses	simulate realistic attacks
Approach	Systematic examination	Goal-oriented attack simulation
Physical security	Depends on scope	Can be included
Digital security	finds technical weaknesses	Tests attack paths and detection
output	Vulnerability report	Attack findings and response evaluation

Problem Solving Approach

For a vulnerability assessment, The banks security team would examine systems for outdated software, weak authentication, insecure configurations, and exposed services. The findings would be prioritized for correction.

For a red team exercise, authorized testers might simulate attempts to bypass physical access controls and exploit approved digital attack paths. The banks ability to detect, investigate, and respond would Then be evaluated.

Accuracy and Justification.

Both activities, require written authorization, confidentiality, defined scope, and Rules of Engagement. The red team must avoid unecessary disruption and protect customer information. The red team must avoid unnecessary harm.

Conclusion.

A vulnerability assessment focuses primarily on finding and reporting weaknesses, whereas a red team exercise focuses on simulating realistic attacks and evaluating detection and response. Both approaches improve the banks overall security